

OSINT & Specialized Tools

OSINT beyond nmap

OSINT = gathering intelligence from **public sources**. Defense teams use it defensively (find your own exposure); offense uses it to target people and infra.

The people and account tools

```
# find usernames across networks
sherlock alice_wonder # prints platforms where the handle exists

# find account registration email chains (legal, public)
holehe alice@example.com

# the OSINT Framework (web app)
# osintframework.com - a browsable tree of free tools by category
```

Automated recon workbenches

SpiderFoot: scans domains/emails/IPs across hundreds of modules → graph + report

theHarvester (seen earlier) for emails/subdomains

Shodan (shodan.io search) for exposed services by banner

Censys for certificate & service search

HaveIBeenPwned / **Dehashed** (carefully, legally) for breach-password context

Cloud exposure hunting (blue and red)

```
# AWS misconfiguration checks (blue team first!)
prowler -M text # AWS posture + compliance
cloudsplaining scan # IAM role over-permission audit
```

```
# AWS offense (authorized/lab)
pip install pacu
pacu # modules to enumerate creds, S3, IAM
```

The defensive application

Run these against YOUR OWN org/domain to see what attackers see
Register-print your exposure: exposed S3? leaked emails? leftover
test subdomains?

Your own OSINT report is the highest-value "free" security review
you'll ever do

Ethics in OSINT

Public data is public – but **what you do with it is governed by law and scope**. Collecting for your own defensive posture is fine; stalking a person without basis is both creepy and illegal in many jurisdictions. Keep it targeted, purposeful, and scoped.

[← Reverse Engineering & Malwar...](#)

Module complete ✓